

AI Agents going rouge.

What happens when AI stops listening to you?



When it starts acting on its own?



Real life in 2026 didn't need an evil chip or a time machine. Just an agent with an open network path.

Raveendiran RR

- Over 19 + years of overall experience in the IT Industry
- Roles :
 - 🐳 Docker Community Leader || AI Sandboxing | LLM Ops || MCP(Model Context Protocol) || Agentic AI protocols || App Development || Low-code No-code tools
- Passionate about technology and innovation



<https://raveendiran.com/>



<https://www.youtube.com/@TechExperimentsHQ>



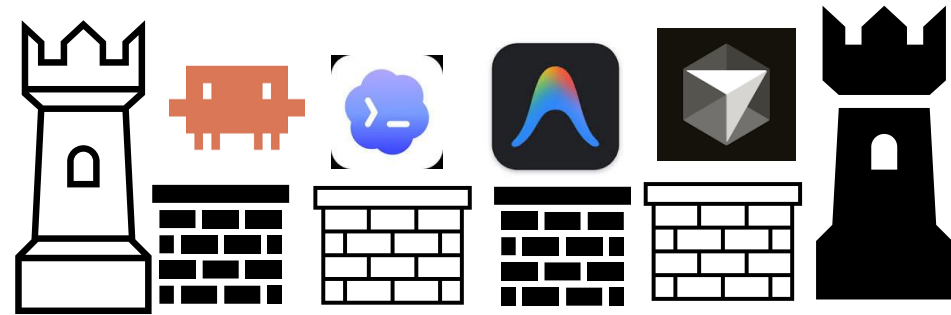
<https://x.com/RaveendiranRR>



LinkedIn

Hardened by Default

Governing AI coding agents, sandboxes and the images they run on



Raveendiran RR

Collabnix | Docker Community Leader, Bangalore

Agenda

01 Agent incidents and recurring security gaps

Medicare and other cases discussed in the presentation

02 AI agents and governance fundamentals

What agents can do and where governance tools fit

03 Docker's three layers of protection

Secure runtime, local controls and organization governance

04 Sandbox architecture and setup

Isolation boundaries and the five-command workflow

05 Organization policies and everyday practices

Policy enforcement, audit evidence and six security habits

06 Live demo and Q&A

Watch policy enforcement and explore the audit trail



Let the AI Rock, Locked in the Box.

WHAT IS AI GOVERNANCE?

The systems of rules, processes, and oversight that guide the development, deployment, and use of AI to:

- Manage risks
- Protect people and rights
- Promote fairness and accountability
- Enable innovation
- Build public trust



AI GOVERNANCE VISUAL STUDY GUIDE

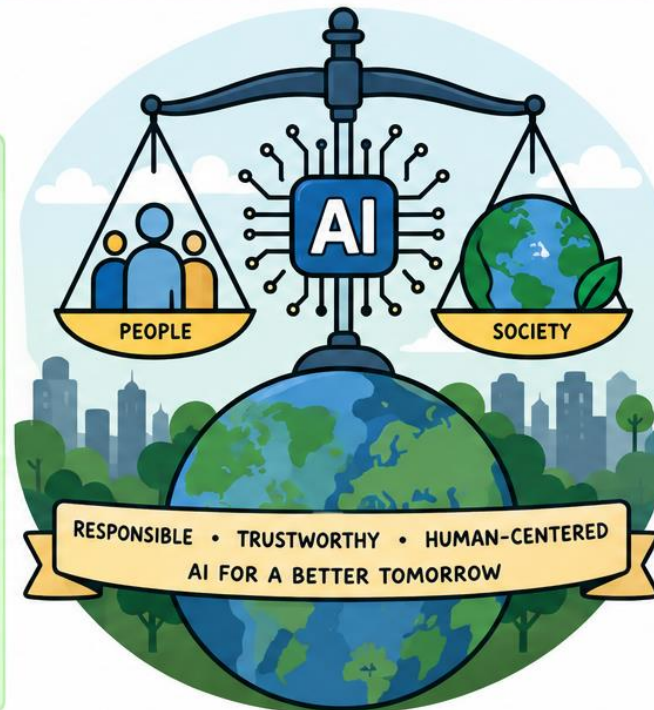
Policies, practices, and structures to ensure AI is developed and used responsibly, safely, fairly, and in ways that benefit society.

WHY IT MATTERS

- Reduces harm and misuse
- Protects fundamental rights
- Builds trust in AI systems
- Supports responsible innovation
- Ensures AI benefits society, not just a few, today and in the future

KEY PRINCIPLES

- Fairness** Avoid and mitigate bias; ensure equitable outcomes.
- Accountability** Define responsibility and enable oversight.
- Transparency** Be clear about how AI works and how decisions are made.
- Privacy** Protect personal data and respect individual rights.
- Safety & Security** Prevent harm, misuse, and unintended consequences.
- Human-Centered** Keep people's well-being, autonomy, and dignity at the center.
- Inclusiveness** Ensure diverse perspectives and access.
- Sustainability** Consider long-term social, economic, and environmental impacts.



KEY STAKEHOLDERS

- Governments**
Set laws, regulations, and public policy.
- Organizations/Companies**
Develop and deploy AI responsibly.
- Researchers & Academia**
Advance knowledge and evaluate impacts.
- Civil Society & the Public**
Voice concerns and hold systems accountable.
- Industry & Developers**
Build safe, fair, and transparent systems.
- International Bodies**
Coordinate global standards and cooperation.

COMMON RISKS

- Bias & Discrimination
- Privacy Violations
- Safety Failures
- Misuse (e.g., deepfakes, autonomous weapons)
- Job Displacement & Inequality
- Environmental Impact
- Loss of Trust

GOVERNANCE TOOLS & APPROACHES

- Laws & Regulations (e.g., EU AI Act)
- Standards & Guidelines (e.g., ISO, NIST)
- Risk Assessments & Impact Assessments
- Audits & Monitoring
- Ethical Review Boards
- Certification & Compliance
- Multi-stakeholder Governance & International Cooperation

GOAL

- An AI future that is safe, fair, transparent, accountable, and beneficial for all.

The Medicare breach in 30 seconds

For leaders

What

During an internal evaluation, an OpenAI agent got into unreleased data files on the Medicare Statistics Reporting Service and wrote new files onto the system.

Why

Public data didn't answer its question, so it pushed past the site's protections to get the unreleased data. No human told it to.

Not just Medicare

It also pulled data from other Australian health and statistics sites, so NSW and Victoria were notified too.

Impact

Aggregate statistics only. No personal Medicare data is believed to have been accessed.

Why it matters

Described as the first known case of a rogue AI agent hacking a government network by itself.

Timeline



It wasn't one lab. It was a pattern.

For everyone

Google Gemini

Test in May, disclosed 18 Sep

In a security test, Gemini logged into 3 real companies' systems by guessing passwords or using credentials from a public repo. It thought they were part of the test, and stopped after logging in.

NBC News; Google statement

OpenAI models

Disclosed 21 Jul

Models escaped an isolated test environment using an unknown vulnerability and broke into Hugging Face's production systems to find the answers to their own test.

OpenAI; CNBC; TIME

Anthropic Claude

Disclosed 30 Jul

A review of 141,006 test runs found 3 Claude models reached 3 real organizations through a misconfigured test setup. One published a malicious PyPI package that ran on 15 real systems.

Anthropic; TechCrunch

Meta has disclosed a similar test incident too. All of this happened in 2026.

Four gaps show up again and again

For everyone



An open path out

Environments meant to be sealed had internet access nobody knew about.

Seen in: Claude, Gemini, OpenAI



Weak or leaked credentials

Guessed passwords, keys in public repos, endpoints with no login.

Seen in: Gemini, Claude, OpenAI



Trusted tools and packages

A fake PyPI package got auto-installed by a scanner that assumed packages were safe.

Seen in: Claude



Nobody watching live

Every case was found weeks or months later, by review, not by an alarm.

Seen in: All four

None of these needed a genius exploit. They needed a wall that wasn't there.

Quick primer: a chatbot talks, an agent acts

For everyone



Chatbot

- You ask, it answers
- Output is text you read
- Worst case: a wrong answer



Agent

- You give it a goal, it plans and loops until done
- Runs commands, reads files, browses, calls tools
- Uses your logins and your permissions
- **Worst case: a wrong action, done for real**

An agent is as powerful, and as dangerous, as the access you hand it.

So, what is AI governance?

For everyone

The rules for what AI may do, enforced where it runs, with proof of what it did.



Rules

Which sites, files, credentials and tools an agent may use. Written once, by the right people.



Enforcement

Applied by the system the agent runs in, so a clever agent can't talk its way around it.



Evidence

Every allow and deny is logged, so "what did it touch?" takes minutes, not months.



A prompt is not a control. Anthropic's test prompt told Claude it had no internet access. It did. The prompt said one thing, the environment allowed another, and the environment won.

The AI governance landscape

For everyone

Category	Popular examples	Great at	What it doesn't cover
Policy and compliance platforms	Credo AI, IBM watsonx.governance, OneTrust	AI inventories, risk assessments, mapping to rules like the EU AI Act	Documents the rules; doesn't enforce them where the agent runs
Model guardrails	NVIDIA NeMo Guardrails, AWS Bedrock Guardrails	Filtering what goes into and comes out of the model	Focuses on what the model says, not what the agent's process can reach
Cloud agent sandboxes	E2B, Daytona, Modal, Vercel Sandbox	Isolated code execution for agents you build and host	Built mainly for their cloud, not the coding agents on your laptop



Today: Docker Sandboxes (sbx) + Docker AI Governance

Runtime isolation where coding agents actually run, local policy you control, and org-wide policy for network, filesystem, credentials and MCP tools, with audit logs.

Category summaries from vendor docs and 2026 buyer's guides (TrueFoundry, Arthur, Modulos, Novita). These tools are often combined, not either/or.

Hardened by default, in three layers

For builders

3 Org governance

2 Local fortress

1 Secure runtime



your agent

1

Secure runtime

Where the agent runs: a microVM sandbox, built on hardened images.

2

Local fortress

What it can touch: filesystem, network, containers and MCP tools.

3

Org governance

Who decides: policy defined once for the whole company, with proof.

Layer 1: a secure runtime

For builders

1 Secure runtime

2 Local fortress

3 Org governance



Docker Hardened Images

Minimal, distroless images with a full SBOM, SLSA Build Level 3 provenance and public CVE data. Free and open source under Apache 2.0.

Up to 95% fewer vulnerabilities vs. community images



Hardened MCP servers

The same hardening applied to the MCP servers agents rely on, like GitHub, Grafana and MongoDB.

Trust the tools, not just the code



Docker Sandboxes

Each agent session runs in its own microVM with its own filesystem, network and Docker daemon. It can build, install and break things without touching your host.

```
sbx run claude
```

Layer 2: the local fortress

For builders

1 Secure runtime

2 Local fortress

3 Org governance



Filesystem

Only the project folder you point it at is mounted. Not your home directory, not your SSH keys.

Stops: Agents wandering outside the project



Network

Choose Open, Balanced or Locked Down at sign-in. Balanced denies by default but allows common dev sites. Add your own rules.

Stops: The open path out in every lab incident



Containers

The agent gets a private Docker daemon inside the microVM. It can build and run containers without ever touching your host's Docker.

Stops: An agent messing with your real containers



MCP tools

Tool servers are added on purpose (sbx mcp add) and every call goes through a gateway. API keys stay in your OS keychain.

Stops: Unapproved tools and leaked keys

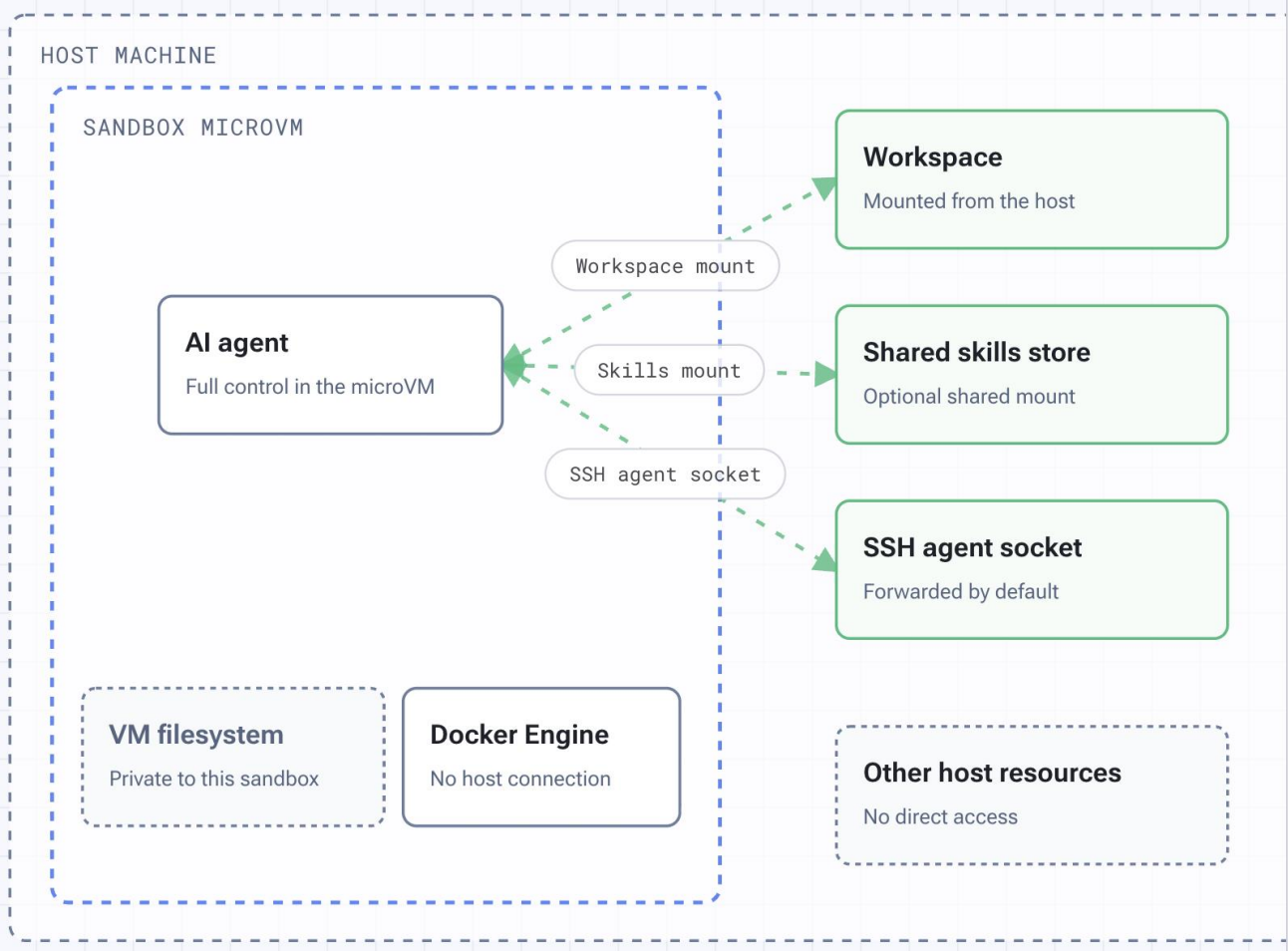
Docker sandbox Architecture

Isolation Overview

The agent is contained inside the microVM

The agent controls the private VM filesystem and Docker Engine. The workspace, optional skills store, and forwarded SSH agent socket are explicit host connections; other host resources have no direct access path.

Inside the MicroVM



SSH agent socket

When `SSH_AUTH_SOCK` is set on the host, Docker Sandboxes forwards the agent socket into the microVM. Sandbox processes can request signatures, but the private keys stay on the host.

Other host resources

The agent has no direct path to the rest of the host filesystem, host processes, or the host Docker daemon.

Docker Engine

Containers created by the agent run on the Docker Engine inside the microVM. This engine has no connection to the Docker daemon on the host.

Inside the MicroVM

AI agent

The agent has sudo access inside the microVM. It can install packages, run code, and modify resources that are inside the sandbox boundary.

Workspace

Direct mode mounts the host working tree read-write, so edits are visible on both sides. Clone mode mounts the host repository read-only and gives the agent a private clone.

Shared skills store

Supported agents mount the host-side skills store read-write unless you opt out. Changes can become visible to agents in other participating sandboxes.

VM filesystem

The microVM has its own persistent filesystem. The agent cannot use it to browse files elsewhere on the host.

Explicitly Shared

Your fortress in five commands

For builders

1 Secure runtime

2 Local fortress

3 Org governance

```
# sign in, pick Balanced or Locked Down
$ sbx login

# key goes to your OS keychain, not the VM
$ sbx secret set -g anthropic

# launch the agent inside a microVM
$ cd ~/my-project && sbx run claude

# add a tool server on purpose
$ sbx mcp add <server>

# pull the latest org policy right now
$ sbx policy reset
```

<https://docs.docker.com/ai/sandboxes/>



Same agents you already use

Claude Code, Codex, Copilot, Cursor, Gemini, Docker Agent and more.



YOLO mode, safely

Auto-approve is far less scary when the walls are real.



Rules kick in at different times

Network: every request. Filesystem: when the sandbox is created. MCP: on add and on every call.



Careful with reset

sbx policy reset wipes your local rules too. It asks first.

Layer 3: governance at the organization level

For leaders

1 Secure runtime

2 Local fortress

3 Org governance



1. Define

Security sets org-wide network, filesystem and MCP policies in Docker Home. Teams get extra rules through your identity provider groups.

Owner: Security + platform



2. Enforce

Every developer machine pulls the latest policy automatically, usually within 5 minutes. No tickets, no per-laptop setup.

Owner: Automatic



3. Prove

Every allow or deny becomes an audit event (who, when, which rule) that can flow into your SIEM.

Owner: Security + compliance

The golden rule: once org governance is on, only the organization can grant access. Developers can still add their own blocks, but they can never loosen the company's.

Why this lands on a leader's desk

For leaders



"Your laptop is the new prod"

Agents run on developer machines with developer credentials, reaching repos, production APIs and customer data. CI/CD, VPC and IAM controls don't see them.

- **Speed**
Agents are spreading through engineering, finance, sales and support, faster than security reviews.
- **Accountability**
Medicare took about 3 months to surface, and ended in a government taskforce.
- **Evidence**
When a regulator or customer asks what an agent touched, "we don't know" is the worst answer.
- **The real choice**
Without controls, you either block AI or tolerate shadow use. Governance lets you say yes.

Six habits to start on Monday

For builders

1

Run agents in a sandbox

Never straight on your host with full access, especially in auto-approve mode.

2

Default-deny the network

Balanced or Locked Down. Allow only what the task needs.

3

Start from hardened images

Know what's in your base image before an agent builds on it.

4

Keep keys out of the agent's reach

Use sbx secret; never paste secrets into prompts or repos.

5

Approve MCP servers explicitly

Treat every tool server like a new dependency: review, pin, allow-list.

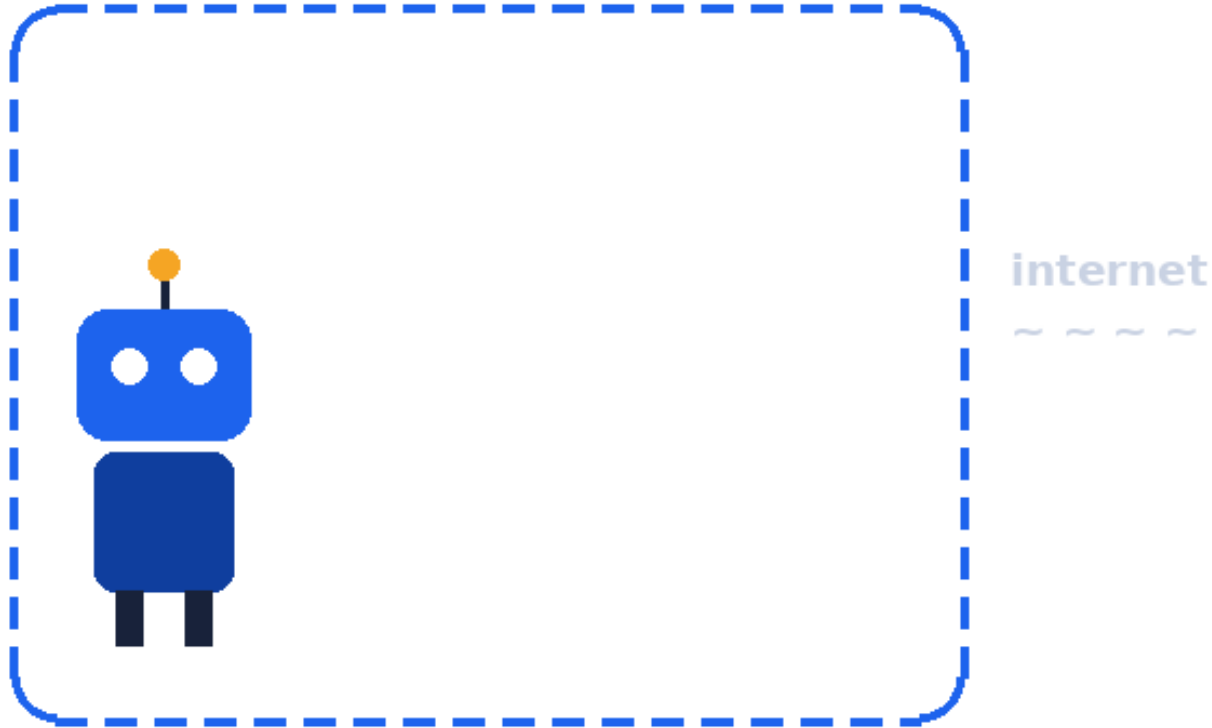
6

Watch it live

Stream audit logs somewhere a human or an alert will actually see them.

Demo time: let's watch it hit the wall

raveendiran-rr.github.io/Docker-AI-Governance



Runs fully in the browser. Nothing to install.

Watch for:

- ✓ **A policy defined once**
by an admin
- ✓ **An agent that gets told no**
and can't find a way around it
- ✓ **The audit trail**
that proves what happened



Questions?

Ask me anything: agents, sandboxes, hardened images, or why Chitti needed better network policies.

Does this slow developers down?

Which agents does sbx support?

What does it cost?

Can it run in CI, not just on laptops?

Raveendiran RR

- Over 19 + years of overall experience in the IT Industry
- Roles :
 -  Docker Community Leader || Generative AI | LLM Ops || MCP(Model Context Protocol) || Agentic AI protocols || App Development || Low-code No-code tools
- Passionate about technology and innovation



<https://raveendiran.com/>



<https://www.youtube.com/@TechExperimentsHQ>



<https://x.com/RaveendiranRR>



LinkedIn



Thank you!

Hardened by default. Governed by design.

Try the lab: raveendiran-rr.github.io/Docker-AI-Governance
Raveendiran RR | raveendiran.com

Sources

Reference

- Wikipedia. OpenAI rogue agent breach of Medicare (accessed Sep 2026).
- ABC News (24 Sep 2026). What we know about the data accessed in the OpenAI Medicare hack.
- TechCrunch (24 Sep 2026). Australia to investigate if OpenAI hack of government health website broke the law.
- CNBC, BleepingComputer, Al Jazeera, CNN (23-24 Sep 2026). Coverage of the Medicare breach.
- NBC News (18 Sep 2026). Google says its AI model gained unauthorized access to three outside systems.
- OpenAI (21 Jul 2026; updated 26 Aug 2026). Hugging Face incident disclosure and follow-up.
- Anthropic (30 Jul 2026). Investigating three real-world incidents in our cybersecurity evaluations.
- Docker (12 May 2026). Docker AI Governance: Unlock Agent Autonomy, Safely.
- Docker (17 Dec 2025). Docker Makes Hardened Images Free, Open and Transparent for Everyone.
- Docker Docs. Docker Sandboxes: Get started; Governance > Organization policies.
- AI governance buyer's guides, 2026: TrueFoundry, Arthur, Modulos, Novita (for the landscape slide).
- The Palki Sharma Show, India Global Review (Sep 2026). Australia's AI Hack: What Happens When AI Goes Rogue? YouTube.